Response to the reviewers, rounds 3 and 4

Ronald Rethabile Malamule Mahomane
Department of Computing, Mathematical and Statistical Sciences, University of Namibia, Windhoek
School of Pathology, Faculty of Health Sciences, University of the Witwatersrand, Johannesburg
Basis Energy, Victoria, Australia
ron@basisenergygroup.com

September 2026

Scope

This letter answers two further pre-submission reviews of the two manuscripts: an adversarial referee report (round 3, `docs/panel_review/9_adversarial_referee.md`) and a panel of six referees in sequential statistics, statistical disclosure control, differential privacy, security engineering, central banking and reproducibility (round 4, `docs/panel_review/10_round4_panel.md`). The manuscripts are the Journal of Privacy and Confidentiality article *Adaptive certification of attack-conditional disclosure risk across release programmes* with its supplement (the article), and the IFC working paper draft *Governing privacy risk across repeated statistical releases* with a new online appendix (the long form). The answers to rounds 1 and 2 are in `response_to_reviewers_round2.pdf`.

What changed the results

1. **The synthetic loan panel had a defect, now fixed.** Every loan was forced to be live in the first vintage, a third of loans left in the second vintage and came back in the third, and no loan entered after the first. That gave an adversary who knows a loan's history an artificial signal and made the differencing result an identity. In the new panel some loans are originated during the panel, each loan leaves with a monthly hazard of 0.04 and does not return, and the stock stays near 27,000. Every credit-register figure in both manuscripts has been recomputed.

2. **The pooled attack now uses all the knowledge the threat model grants.** An adversary who knows the target's history also knows when the target is absent. The attack now excludes a candidate whose pattern of appearances differs from the target's in either direction, where before it excluded only candidates missing from vintages in which the target was present. Ties are broken at random.

3. **The floors are much higher, and the policy message changes.** Per release the file passes with no suppression. An adversary who pools the six vintages and knows the history needs a floor of 75 (selection passed 50, confirmation did not), and one who also holds a reading per vintage needs 150, which keeps 20 per cent of loans and 4 per cent of exposure. An insider who knows exposure exactly defeats every floor up to 300. Both manuscripts now conclude that against a history-aware adversary a loan-level release is the wrong product, and that aggregates or access in a secure setting are the realistic options.

4. **Floors are chosen by a valid rule and confirmed.** Fixed-sequence testing from the strictest level down replaces "smallest level whose bound passes", each floor is confirmed on an independent draw, and a failed confirmation moves to the next stricter level. The same rule is repeated over 20 register draws and three levels of reading noise, and at four tolerances.

5. **The article's experiment tests the right error.** A release chain declares the three attacks before the audit and tests each at the full level at every floor (a fixed sequence of intersection-union tests). It chose 150 in 19 of 20 attack streams and never chose an unsafe floor, and an operating-characteristics check on Bernoulli streams at the estimated risks gave no unsafe choice in 400 runs.

6. **The audit process has a threat model.** Both manuscripts now separate the outside adversary from the operator who runs the audit, list what must be trusted, and measure three attacks on the process: seed grinding, shadow audits and bets chosen after the outcome. The repository implements committed randomness for targets, bets recorded before each attack, and a hash-chained ledger, and both texts say plainly that a library is not a security boundary.

Round 3: adversarial referee

Item	Response
A1	Fixed. The floor for pooling alone, for the full attack and for each piece of knowledge is reported separately (long form Table *robust*; article Section 5.3).
A2	Fixed. History is a listed piece of knowledge in both threat models, with who holds it. Without it, pooling adds nothing on this register, and both texts now say this holds by construction of the generator.
A3	Fixed in part. The pseudonym condition is stated wherever it is used, and the texts say a persistent pseudonym makes the programme one finer release. With exposure published exactly every loan can be relinked from published fields; with exposure to one significant figure, 10 per cent can. We did not run a full relinking attack on rotated, perturbed releases.
A4	Fixed. One success event throughout. Subgroup control is an intersection-union test with no Bonferroni correction; the largest size class is audited on its own stratified draw.
A5	Fixed. Fixed-sequence selection with confirmation (long form Proposition *fixedseq*).
A6	Fixed in part. Floors over 20 register draws and three noise levels are reported, with the design standard deviation and its interval. The audit experiment still uses one register.
B1	Addressed. The article adds the expected-length bound with its relation to the lower bound for any valid test, and release chains; the chain proposition now allows the next member to depend on earlier outcomes. We state that these rest on known arguments (Wald's identity, fixed-sequence and intersection-union testing).
B2	Answered honestly. The article now says that adaptive registration alone does not need e-processes, and that the gate's value is free monitoring. The comparator that registered everything at the start is now stopped at its first failure, as the text says.

B3	Fixed. The article explains audit length by Proposition 3 and shows that a capped bet has negative drift, and so certifies only by chance, when the risk lies above the cap.
B4	Fixed. The toy audit runs through the shipped gate.
B5	Fixed. "Cell-count floors".
B6	Open. The long form is supplied to the editor with the submission. A public deposit (arXiv or an IFC number) is needed before submission.
B7	Fixed. Floors at four tolerances; 0.09 is noted as the average-risk benchmark in clinical-data guidance.
B8–B12	Fixed: literature on audits by betting and sequential republication; code claims reworded; supplement commands corrected; proposal model reduced to a paragraph; ties broken at random in the attack used for the floors and the audit (the older pipeline attack keeps first-index ties, which are rare with continuous readings).
C1–C15	Fixed in the long form, with the new figures. The noisy-count rows and the real-data neural runs are removed; the census utility charges for coarsening; the shift bound uses the Bernoulli divergence on the upper bound.
D1	Fixed. The pipeline was rerun and its manifest matches; manifests are written for the article's outputs.
D2	Unchanged in the checker; both texts now say which figures it does not cover.

Round 4: panel

Sequential statistics. *Theorem correct; the chain proposition is online fallback; the $\alpha/3$ split is not needed; the frozen comparator audits levels it never needs; comparators are weak; 20 streams cannot test validity; the cap is ad hoc.*

Response. All but the last two are fixed as described above, with online fallback, Hsu and Berger, gatekeeping and graphical procedures cited. Validity is now checked on Bernoulli streams. The looks design is labelled as Bonferroni over looks. We did not replace the capped plug-in bet by a truncated Beta mixture or add exact group-sequential boundaries; both are listed as further work.

Disclosure control. *The history adversary, the tolerance, average against maximum risk, relinkage through continuous values, utility, and in-file prosecutor risk on the Census file.*

Response. The history adversary, the tolerance, subgroup control, rotation and utility in credit volume are addressed above. The Census results are presented as a demonstration of the pipeline, and the tolerances implied by κ on that file are no longer offered as policy numbers. Journalist targets, per-record risk distributions and a p% rule for lender contributions are not yet run.

Differential privacy. *The declared attack was not optimal for the declared knowledge; an insider with exact exposure; DP treated unfairly; the noisy-count arm; the scope of the shift bound; missing auditing literature.*

Response. The attack now uses the full likelihood of the history. The insider is its own adversary. Both manuscripts give the hypothesis-testing bound $e^{\varepsilon}\kappa + \delta$ and say it is stronger than any certificate from the gate. The noisy-count arm is removed. The shift bound is presented as a sensitivity statement with the attack held fixed, and reading noise is analysed directly. The auditing literature is added. A borrower-level DP release attacked by the same attacks is further work.

Security engineering. *No security property, no audit-process adversary, no trusted base; seed grinding; read-only state is not a control; post-hoc bets; unkeyed manifests; separation of duties; framework mapping.*

Response. Both security sections are rewritten around two adversaries and five trusted parts, with measured attacks on the audit process. The repository adds committed targets, recorded bets and a hash-chained ledger, and the texts say what these do not provide: a separate registry service, signing keys, external time stamps and enforced separation of duties. We claim no conformity with any standard.

Central banking. *The panel defect; utility in loans not credit volume; loan-level releases are not what central banks publish; the insider harm; legal basis; length.*

Response. The panel is fixed and cost is reported in exposure and large-firm loans. The long form now says the loan-level file stands in for securitisation disclosures and research files as seen by accredited users, and that for a history-aware adversary aggregates or secure access are the realistic products. The governance tuple gains the legal basis, protected parties and access route, citing Regulation 2533/98 and GDPR Recital 26. The long form has an executive summary and an online appendix; its main text is still about 57 pages. Programme analysis of aggregate tables, lender-insider harm to other relationships, and a register with amortising exposure are further work.

Reproducibility. *Stale manifest; seed collision in the truth draws; untraceable figures; stale READMEs; response letter out of date.*

Response. All fixed: the truth draws use disjoint seeds, the estimand check is a shipped script, both READMEs point to the new scripts, and this letter replaces the old one.

Further work stated in the manuscripts

A run on a real register inside a secure environment; a register with outstanding amounts that change each month and dated loan events; journalist target laws; programme analysis of aggregate tables; a registry service that enforces the audit-process controls; exact group-sequential and truncated-mixture designs.